



TORTUGA CYBERSECURITY

ES

Conciencia sobre Phishing y Amenazas Cotidianas

Guía práctica para protegerse en línea



Fundamentos del Phishing y Ataques Homográficos

El phishing consiste en suplantar a una entidad de confianza para que usted entregue sus credenciales, datos de pago o accesos. La mayoría de los ataques llegan por correo o mensajería, imitan la apariencia de un servicio legítimo y lo dirigen hacia una página de inicio de sesión falsa. Una de las variantes más difíciles de detectar es el ataque homográfico: el atacante registra un dominio visualmente casi idéntico al verdadero. Una letra o minúscula puede sustituirse por el número uno, la letra o por un cero, o un carácter latino por otro muy parecido de un alfabeto distinto. Sus ojos leen `examp1e.com` como `example.com`, pero para el navegador son dos servidores completamente diferentes. La defensa es de procedimiento, no de vista: no confíe en un enlace porque se vea correcto. Acceda a los sitios sensibles mediante sus propios marcadores o escribiendo la dirección, y revise el dominio completo antes de ingresar cualquier credencial.

Puntos clave

- ✓ El phishing imita marcas confiables para robar credenciales o pagos.
- ✓ El ataque homográfico sustituye caracteres (1 por l, 0 por o, alfabetos parecidos) para falsificar dominios.
- ✓ Revisar un enlace a simple vista no es confiable; la sustitución está diseñada para engañar la mirada rápida.
- ✓ Ingrese a sitios sensibles por marcadores propios o escribiendo la dirección, nunca desde enlaces recibidos.

→ HÁGALO HOY

Guarde hoy en marcadores las páginas de acceso de su banco, su correo y su trabajo, y utilice únicamente esos marcadores de ahora en adelante.



Autenticación de Dos Factores y Gestores de Contraseñas

Las contraseñas fallan de maneras predecibles. Cuando un servicio sufre una filtración, las credenciales robadas se prueban de forma automática contra muchos otros sitios populares, un ataque conocido como relleno de credenciales. Funciona por una única causa raíz: la reutilización de contraseñas. Si la clave de su correo también abre su banca o sus cuentas laborales, una filtración ajena se convierte en un compromiso de todas ellas. Dos controles rompen esa cadena. Un gestor de contraseñas genera y guarda una clave larga y única para cada cuenta, de modo que una filtración queda contenida en el sitio afectado. La autenticación de dos factores derrota la reutilización de credenciales robadas: aunque el atacante tenga la contraseña correcta, no posee el segundo factor que usted controla, sea un código de aplicación o una llave física. Los factores por aplicación o hardware son más robustos que los códigos por SMS, que pueden interceptarse mediante fraude de duplicado de SIM.

Puntos clave

- ✓ Reutilizar contraseñas es la causa raíz que convierte una filtración en muchas.
- ✓ El relleno de credenciales prueba claves filtradas contra otros servicios de forma masiva.
- ✓ Un gestor de contraseñas hace que cada clave sea larga, única y reemplazable.
- ✓ El segundo factor anula la contraseña robada: por sí sola ya no otorga acceso.
- ✓ Prefiera aplicaciones de autenticación o llaves físicas antes que códigos SMS.

→ HÁGALO HOY

Active hoy la verificación en dos pasos en su correo principal; es la cuenta que restablece todas las demás.



Wi-Fi Público, Puntos de Acceso Falsos y VPN

El Wi-Fi público tiene un modelo de riesgo concreto. Cualquier persona puede transmitir una red con el nombre de la cafetería o el aeropuerto donde usted se encuentra, y su dispositivo no puede distinguir el punto de acceso legítimo del falso. Al conectarse a una red controlada por un atacante, este queda en medio de su tráfico y puede observar conexiones sin cifrar, alterar respuestas o redirigirlo a páginas suplantadas. Una VPN cambia exactamente una cosa: cifra el transporte entre su dispositivo y el proveedor de la VPN, por lo que el operador de la red hostil solo ve datos cifrados. Esa garantía es real y valiosa, pero también limitada. Una VPN no limpia un equipo ya comprometido, no le impide escribir su contraseña en una página de phishing y traslada la confianza al proveedor del servicio. Considérela una protección para la conexión, no para el dispositivo ni para la persona que lo usa.

Puntos clave

- ✓ Un punto de acceso falso puede imitar a la perfección el nombre de una red legítima.
- ✓ Esa posición intermedia permite interceptar y manipular su tráfico.
- ✓ La VPN cifra el transporte y deja ciego al operador de la red local.
- ✓ La VPN no repara un equipo comprometido ni evita el phishing.
- ✓ Elija un proveedor de VPN en el que pueda justificar su confianza.

→ HÁGALO HOY

Desactive hoy la conexión automática a redes Wi-Fi abiertas en su teléfono y computadora, para que cada conexión sea una decisión consciente.



Ransomware y la Regla de Respaldo 3-2-1

ALTO IMPACTO

El ransomware cifra sus archivos y exige un pago a cambio de la clave. Las variantes modernas van más allá: buscan en silencio cada disco y carpeta de red que la máquina infectada pueda alcanzar, incluidos los discos de respaldo conectados y las carpetas sincronizadas en la nube, y también los cifran. Un respaldo que vive siempre conectado al equipo que protege puede morir en el mismo incidente. La regla 3-2-1 es la disciplina que sobrevive a ese escenario: mantenga tres copias de sus datos, en dos tipos de medios distintos, con una copia fuera de sitio o fuera de línea. La copia fuera de línea es la que derrota específicamente al ransomware: el software malicioso no puede cifrar un disco desconectado ni una copia aislada física y lógicamente en el momento de la infección. Los respaldos en la nube con versiones y retención también ayudan, porque permiten volver a un punto anterior al cifrado. Su verdadera ventaja es la capacidad de recuperación, no el rescate.

Puntos clave

- ✓ El ransomware cifra todo lo que la máquina infectada alcanza, incluidos respaldos conectados.
- ✓ 3-2-1: tres copias, dos tipos de medios, una fuera de sitio o fuera de línea.
- ✓ Una copia desconectada no puede ser cifrada por el malware del equipo.
- ✓ Los respaldos con versiones permiten restaurar a un punto previo a la infección.
- ✓ Pruebe sus restauraciones; un respaldo sin verificar es una hipótesis, no una garantía.

→ HÁGALO HOY

Copie hoy sus archivos críticos a un disco externo, desconéctelo y guárdelo en un lugar separado de su computadora.

Vishing y Estafas de Soporte Técnico

El vishing es phishing por llamada telefónica. Alguien se presenta como su banco, una oficina de gobierno o una empresa de software reconocida y reporta un problema urgente: un fraude en su cuenta, un virus en su computadora, un paquete retenido en aduanas. Los detalles técnicos cambian, pero las palancas de persuasión no. La urgencia le reduce el tiempo para pensar. La autoridad lo desanima a cuestionar a quien llama. El miedo hace que la consecuencia parezca inminente si no actúa de inmediato. El objetivo es que usted entregue códigos, instale programas de acceso remoto o transfiera dinero mientras sigue desconcertado. La defensa más eficaz es romper el canal que el atacante controla: cuelgue, busque usted mismo el número oficial de la institución y devuelva la llamada. Ninguna entidad legítima se opondrá a eso. Ningún banco ni servicio de soporte real le pedirá leer un código de un solo uso ni ceder el control remoto de su equipo en una llamada no solicitada.

Puntos clave

- ✓ El vishing usa urgencia, autoridad y miedo para apresurar sus decisiones.
- ✓ Las llamadas no solicitadas que piden códigos, acceso remoto o transferencias son hostiles por definición.
- ✓ Colgar y devolver la llamada al número oficial rompe el canal del atacante.
- ✓ Los códigos de un solo uso son para digitarlos usted, nunca para dictarlos por teléfono.

→ HÁGALO HOY

Guarde hoy en sus contactos los números oficiales de su banco y de su emisor de tarjeta, para que la ruta segura de verificación ya exista cuando llegue una llamada sospechosa.